

EXPLOITED VULNERABILITY ADVISORY: CVE-2026-48710

Summary

CVE-2026-48710 in Kludex Starlette is being actively exploited in the wild. Starlette is a lightweight ASGI framework/toolkit. Prior to version 1.0.1, the HTTP `Host` request header was not validated before being used to reconstruct `request.url`. Because the routing algorithm relies on the raw HTTP path while `request.url` is rebuilt from the `Host` header, a malformed header could make `request.url.path` differ from the path that was actually requested. Middleware and endpoints that apply security restrictions based on `request.url` (rather than the raw `scope` path) could therefore be bypassed. Users should upgrade to a version greater than or equal to version 1.0.1, which validates the `Host` header against the grammar of RFC 9112 §3.2 / RFC 3986 §3.2.2 when constructing `request.url` and falls back to `scope["server"]` for malformed values. CISA requires federal remediation by 2026-09-16; under the CRA, exploitation of an affected product must be reported within 24 hours.

What we know

- **CVE:** CVE-2026-48710
- **Affected:** Kludex Starlette
- **Exploitation:** Actively exploited, added to CISA KEV on 2026-09-02
- **Severity:** CVSS 6.5 Medium, Network-exploitable, no privileges required, no user interaction (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)
- **Exploitation likelihood (EPSS):** 2%
- **Seen in our tracked reporting:** 1 campaign(s), incl. activity attributed to Qilin
- **Weakness:** CWE-444

Recommended action

Patch CVE-2026-48710 by 2026-09-16. If you cannot patch immediately, restrict network access to the affected service now (segment it, put it behind a VPN, or take it offline) until you can patch. If you ship an affected product, be ready to file the CRA 24-hour report the moment you find it exploited.

Sources: CISA Known Exploited Vulnerabilities, NIST NVD, and Salamander's own corpus. Public data; an advisory of active exploitation, not an incident report. Verify applicability to your estate before acting.